SPLUNK TIER 1 SOC ANALYST

STUDENT WORKBOOK

Fill-in-the-blank exercises and lab worksheets for Lessons 1–15 and Labs 1–10.

This workbook contains no answers. Complete it during or after each lesson using your own Splunk instance and the BOTS v2 Attack-Only dataset (index=botsv2). Your instructor holds the separate answer key.

Name: Glennford S. Atay **Date:** Oct. 14, 2026

Lesson 1 — The SOC Analyst Mindset & What Splunk Is

VOCABULARY CHECK — fill in the blank

1. A **Security Operations Center (SOC)** is a team that watches an organization's systems for signs of attack.
2. A **tier 1 analyst** is the first responder who triages alerts and decides what's worth escalating.
3. A(n) **alert** is a system-generated flag that a pattern of events looks worth a human's attention.
4. **Triage** is the process of quickly sorting alerts by urgency.
5. **Escalation** is the process of handing a confirmed or high-severity issue to a more senior analyst.

STUDENT EXERCISE

In your own words, write one sentence each defining: log, event, alert, triage, escalation.

A **Log** is the written record of activities that happened on a computer or system. An **Event** is an occurrence recorded in a system, such as simply opening a website or logging in on that website, typically found inside a log. An **Alert** is a notification or warning initiated when one or multiple events happens at the same time that suggests a possible malicious activity. **Triage** is the process of quickly segregating, reviewing, and prioritizing tasks by its severity and likelihood for it to become a threat. And lastly, **Escalation** is the act of passing a confirmed or critical incident to higher tiers or specialized departments for deeper investigation and solution.

Lesson 2 — Installing & Verifying BOTS v2

VOCABULARY CHECK — fill in the blank

1. $SPLUNK_HOME on Linux is **/opt/splunk** .
2. $SPLUNK_HOME on Windows is **C:\Program Files\Splunk**.
3. BOTS v2 Attack-Only must be extracted into the Splunk **etc/apps** directory.

BUILD THE SPL — fill in the missing pieces

```
index=botsv2 earliest=0
| stats count by sourcetype
```

STUDENT EXERCISE

Run your completed search above. Record the total event count you see, and list the top 3 sourcetypes by count.

access_combined

activedirectory

apache_error

Lesson 3 — Reading a Single Log Like an Analyst

VOCABULARY CHECK — fill in the blank

1. **_time** is the parsed timestamp field Splunk assigns to every event.
2. **_raw** contains the complete, unmodified original text of an event.
3. A(n) **Field** is a searchable name/value pair extracted from event data.

BUILD THE SPL — fill in the missing pieces

```
index=botsv2 earliest=0
| head 5
```

STUDENT EXERCISE

Expand one event fully. Answer: What happened? When? Which host? Any user, IP, or process visible? Anything unusual?

What happened? Someone tried to apply a coupon code (`20twitter`) at checkout on the store website. The server rejected it with a 404 error `"message":"Coupon code is not valid"`.

When? 8/31/17 at 11:17:11 AM (2017-08-31 03:17:11 UTC).

Which host? `host = jabbah` (sourcetype `stream:http`).

User, IP, or process? Source IP is 212.83.203.115. No username is visible; the session is identified by the PHPSESSID cookie. No process, since this is network data.

Anything unusual? Yes:

- The user agent says “Windows NT 6.333,” which isn’t a real Windows version, so it may be spoofed or scripted.
- The error response leaked a full PHP stack trace with internal file paths.
- The source is an external IP, so it’s worth checking for repeated coupon attempts from it.

Lesson 4 — SPL Fundamentals I — Filtering & Building Blocks

VOCABULARY CHECK — fill in the blank

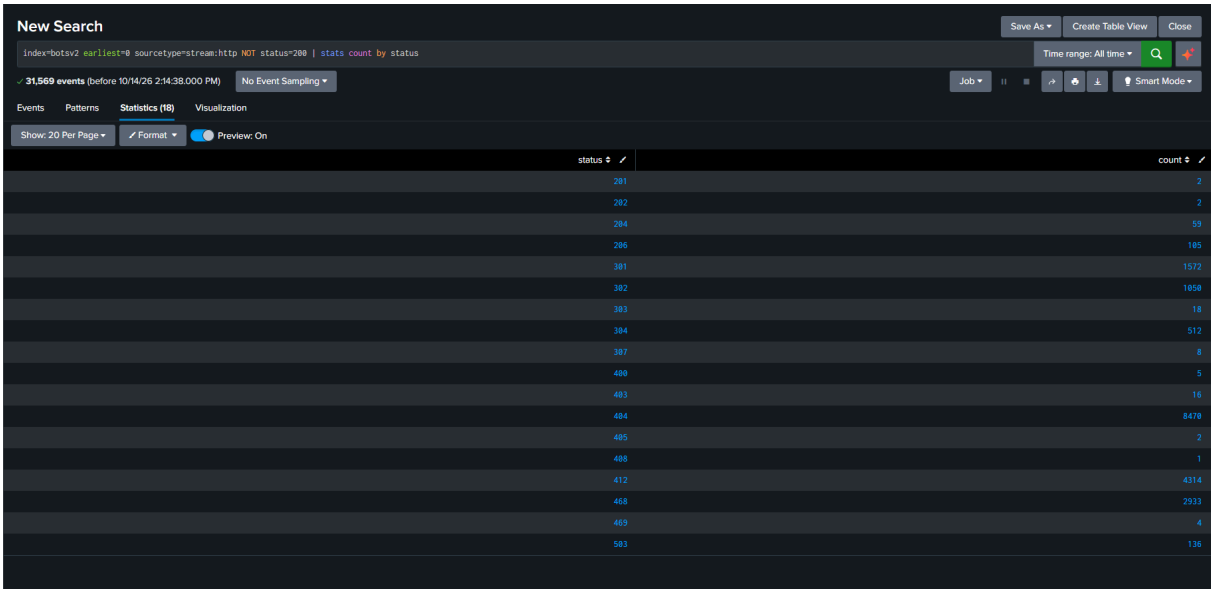
1. In SPL, a bare space between two search terms means **AND** (both must be true).
2. The keyword **OR** means at least one of the grouped conditions must be true.
3. The keyword **NOT** excludes matching events.

BUILD THE SPL — fill in the missing pieces

```
index=botsv2 sourcetype=stream:http
  (status=404 OR status=500)
  NOT status=200
```

STUDENT EXERCISE

Using a sourcetype you discovered in Lab 1, build a search that filters to it AND excludes one common/benign value you notice.



I filtered to the `stream:http` sourcetype I found in Lab 1, and I excluded `status=200` because successful page loads were the most common, harmless value in the events I looked at. Removing them makes errors like the 404 coupon failure easier to spot.

Lesson 5 — Searching Like a SOC Analyst

VOCABULARY CHECK — fill in the blank

1. The analyst search loop, in order: start **broad** → identify useful fields → **narrow** → summarize → investigate.
2. A(n) **Hypothesis** is a plain-language guess to test, not an assumed fact.

BUILD THE SPL — fill in the missing pieces

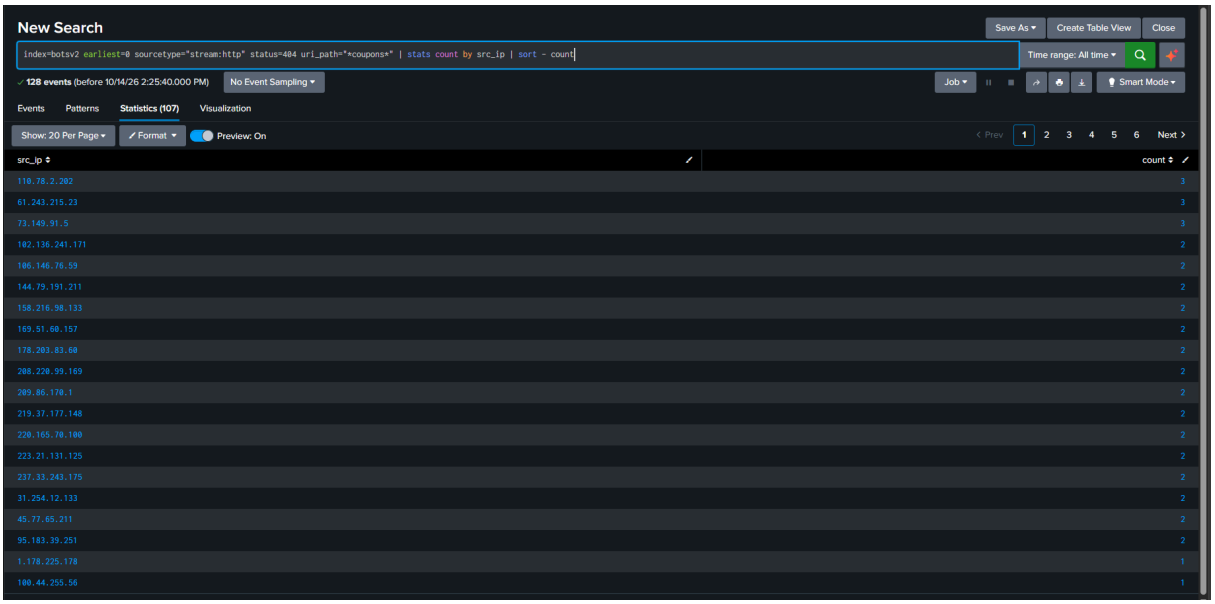
```
index=botsv2 user=*
| stats count by sourcetype
| sort - count
```

STUDENT EXERCISE

Write one search hypothesis in plain English about the BOTS v2 environment, then build SPL that actually tests it.

Someone from an external IP is repeatedly trying coupon codes on the Froth.ly store checkout, and the failed attempts (404 errors) are coming from a small number of IP addresses.

index=botsv2 earliest=0 sourcetype="stream:http" status=404 uri_path="*coupons*" | stats count by src_ip | sort - count



Lesson 6 — Time Is Everything

VOCABULARY CHECK — fill in the blank

1. **earliest=0** search from the beginning of indexed time (training-data-only usage).
2. The **span** parameter controls the bucket size in a timechart.

BUILD THE SPL — fill in the missing pieces

```
index=botsv2 earliest=0
| timechart span=1hr count
```

STUDENT EXERCISE

Run a timechart for one interesting sourcetype. Identify the busiest hour and explain what you'd check next before calling it suspicious.

The busiest hour was `2017-08-11 22:00` with `9849`. Before calling it suspicious, I would check which source IPs and URIs account for the spike, what status codes they received, and whether the volume is normal compared to other hours. High volume alone could be legitimate traffic.



Lesson 7 — Security Fields & Field Discovery

VOCABULARY CHECK — fill in the blank

1. The command **fieldsummary** lists every field present in a result set along with counts and top values.
2. A good analyst does not memorize every field — they know how to **find** them.

BUILD THE SPL — fill in the missing pieces

```
index=botsv2 sourcetype="stream:http"
| fieldsummary
```

STUDENT EXERCISE

Run fieldsummary on two different sourcetypes. List three fields present in one but absent in the other.

I ran `fieldsummary` on `stream:http` and `WinEventLog:Security`. The fields `http_method`, `uri_path`, and `http_user_agent` were present in `stream:http` but absent from `WinEventLog:Security`. This shows each sourcetype has its own field set, so an analyst should run `fieldsummary` on a new sourcetype and not assume field names carry over.

Lesson 8 — Windows Telemetry Investigation

VOCABULARY CHECK — fill in the blank

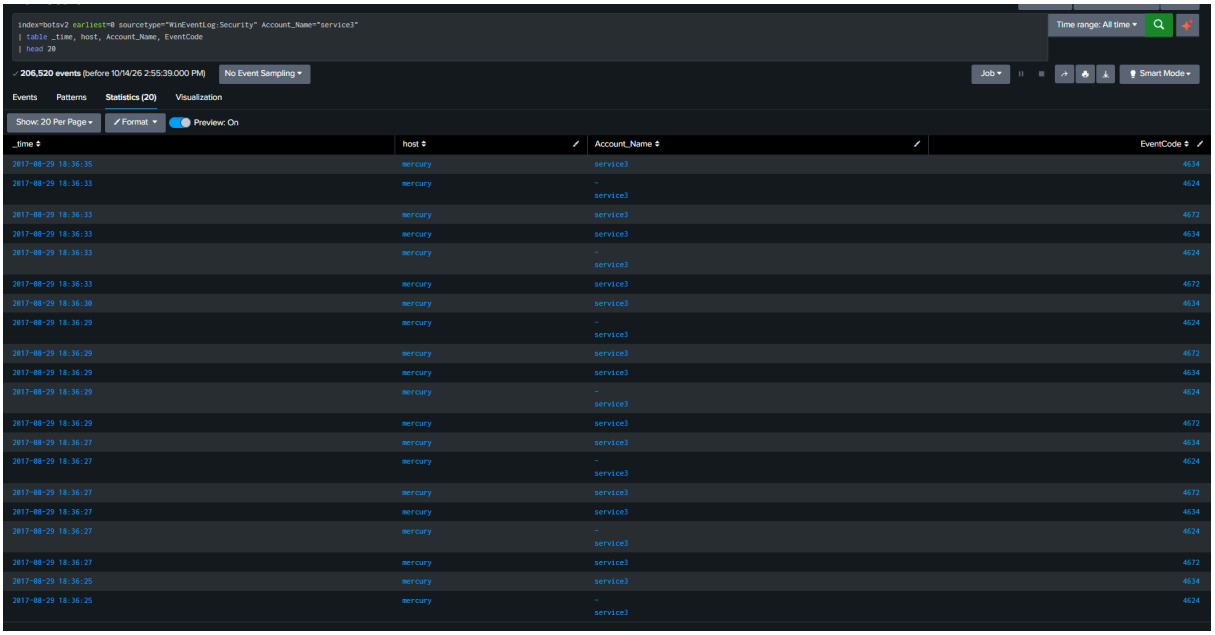
1. Windows telemetry can reveal: authentication, account activity, process creation, and **service** activity.
2. High account activity is / **is not** (circle one) automatically suspicious.

BUILD THE SPL — fill in the missing pieces

```
index=botsv2 sourcetype="WinEventLog:Security"
| stats count by EventCode
| sort - count
```

STUDENT EXERCISE

Identify one high-activity account. Build a table of its events with _time, host, user, and action (or the equivalent field you discovered).



The highest-activity account was `service3` with 206,520 events, all on host `mercury` in the rows I viewed. The table shows a repeating cycle of 4624 (logon), 4672 (special privileges assigned), and 4634 (logoff) every couple of seconds. This looks like automated service-account behavior, so the volume alone is not suspicious. Next I would check whether `service3` logs on from other hosts, whether there are any 4625 failed logons, and whether the activity ever changes pattern or happens at unusual times.

Lesson 9 — Network Log Analysis

VOCABULARY CHECK — fill in the blank

1. The five core network questions: Who **talked** ? Where did it go? What **was sent**? How often? What protocol?

BUILD THE SPL — fill in the missing pieces

```
index=botsv2
| stats count by src_ip dest_ip dest_port
| sort - count
```

STUDENT EXERCISE

Identify one dest_ip that stands out. Investigate which host(s) and user(s) were involved.

I picked `172.31.7.2` (`store.froth.ly`) because it was the destination of traffic from two external IPs: `212.83.203.115` (a failed coupon request that returned a 404 and a stack trace) and `45.77.65.211` (8,966 requests across 4,023 distinct paths, about 90% errors). The traffic was captured on host `jabbah` in `stream:http`. No username appears in the network data, so the only identifier is the `PHPSESSID` session cookie. The evidence indicates this server was the target of external probing. Before calling it suspicious I would check whether any requests returned 200 or POST on sensitive paths.

Lesson 10 — DNS Analysis

VOCABULARY CHECK — fill in the blank

1. The golden DNS rule: unfamiliar domain **does not equal** malicious.
2. Regular, fixed-interval queries from one host may suggest **beaconing/command and control**.

BUILD THE SPL — fill in the missing pieces

```
index=botsv2 sourcetype="stream:dns"
| stats count by query{}
| sort - count | head 20
```

STUDENT EXERCISE

Pick one non-obvious domain from your top-20 list. Investigate the host, frequency, and time window.

I picked `FHFAEBEECACACACACACACACACACACAAA` (13,937 queries). It decodes as a NetBIOS-encoded name for `WPAD`, not a website. In the top 10 sources, all were internal (`10.0.1.x` and `10.0.2.x`), with counts from 263 to 1,291. The activity ran from 08/04/2017 02:08 to 08/29/2017 19:09 (about 25.7 days, 616.9 hours for the longest-running host). In the hourly view I saw, activity occurred in the first hour and then stopped, which suggests bursts and not a steady timer, though that view covered only 20 hours. An unfamiliar name does not equal malicious. The evidence indicates routine WPAD lookups by many internal machines. I have not yet confirmed which host, if any, answered them, so I rate it **benign-leaning** pending that check. I would escalate if an unexpected host replied, since a rogue WPAD responder is a known attack technique.

Lesson 11 — HTTP / Web Analysis

VOCABULARY CHECK — fill in the blank

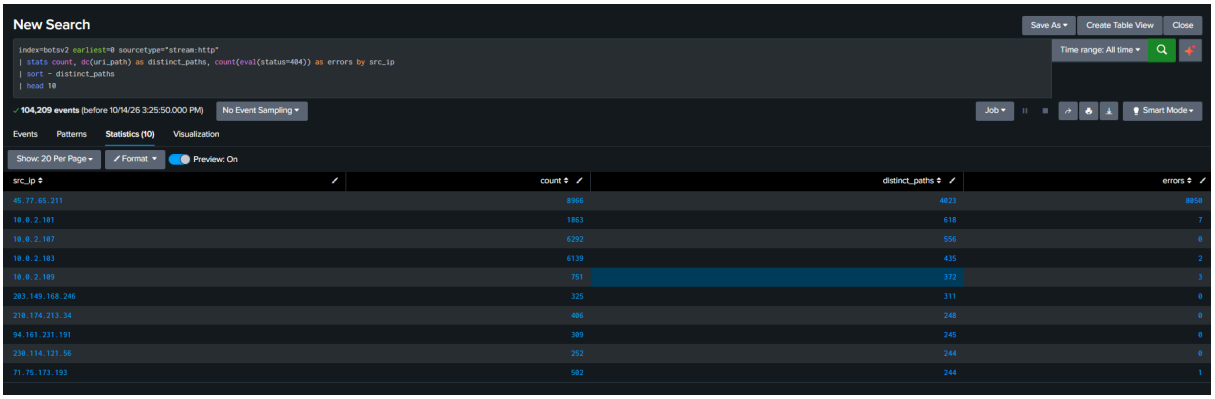
1. A spike in **404** responses from one source often suggests enumeration/scanning.
2. Scanning behavior looks like: many distinct paths, high **error** rate, low repeat.

BUILD THE SPL — fill in the missing pieces

```
index=botsv2 sourcetype="stream:http" status=404
| stats count by uri
| sort - count
```

STUDENT EXERCISE

Find one src_ip requesting an unusually high number of distinct URIs. Inspect what those paths are.



45.77.65.211 made 8,966 requests to the web server, covering 4,023 distinct paths, and 8,050 of them returned errors (about 90%). That is scanning behavior: many distinct paths, a high error rate, and few repeats. This IP is external, so it is not internal traffic. Before calling it malicious I would check the user agent (to see if it is a known scanner tool), whether any requests returned 200 (meaning it found something), and the time window. I would also check whether the same IP appears in other data sources, and whether I can match it to a scheduled authorized scan.

Lesson 12 — Stats Mastery — sort, dedup, top, eval

VOCABULARY CHECK — fill in the blank

1. **count** counts total events; **dc**(field) counts unique values of that field.
2. The **dedup** command removes duplicate events, keeping one per unique field value.
3. The **eval** command creates or transforms a field.

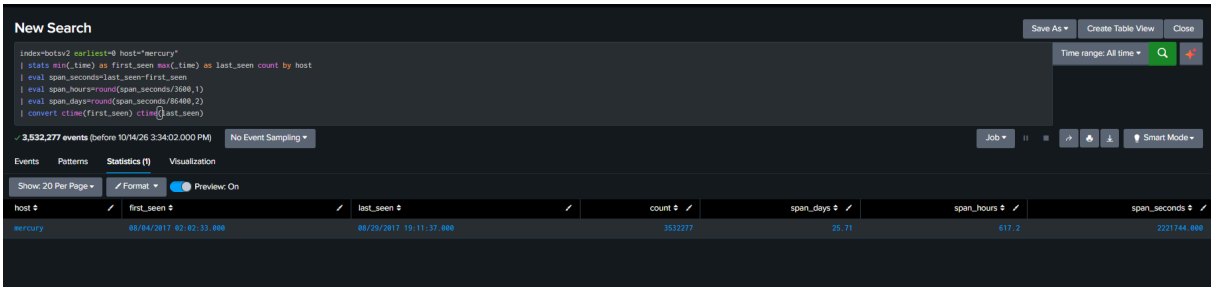
BUILD THE SPL — fill in the missing pieces

```
index=botsv2
| stats min(_time) as first max(_time) as last by host
| eval span=last-first
```

STUDENT EXERCISE

Using eval, calculate the activity time span (first-seen to last-seen) for one host of your choice.

I chose host `mercury`. Its first event was at 08/04/2017 02:02:33 and its last at 08/29/2017 19:11:37, a span of 2,221,744 seconds (617.2 hours, about 25.7 days) across 3,532,277 events. I calculated it with `eval span_seconds=last_seen-first_seen`. The span shows only the window when the host produced logs, not that it was active the whole time, so I would check a timechart for gaps or bursts before drawing conclusions.



Lesson 13 — Correlation — Thinking Across Data Sources

VOCABULARY CHECK — fill in the blank

1. Correlation chain, in order: IP → **Host** → User → **Process** → Network connection → Domain → Timestamp.

BUILD THE SPL — fill in the missing pieces

```
index=botsv2 dest_ip="172.31.7.2"
| stats values(src_ip) values(host) by dest_ip
```

STUDENT EXERCISE

Starting from the suspicious IP identified in Lab 2, build a cross-sourcetype timeline for the host involved, covering ±30 minutes around the activity.

I built a cross-sourcetype timeline for host `gacrux` (target `172.31.4.249`, `www.brewertalk.com`). The scanner `45.77.65.211` made about 8,966 HTTP requests starting 08/11/2017 22:40:57. A second external IP, `52.40.10.231`, communicated with the server from 22:30:05 on 08/11 to 23:31:59 on 08/16, mainly over MySQL on port 3306 (3,164 `stream:mysql` events) and some HTTP on port 80 (12 events). The activity was bursty, with most events in the 22:00 hour on 08/11 and a second burst at 17:00 on 08/12 that was mostly database and Linux audit and auth events, not web requests. The evidence indicates scanning from `45.77.65.211` and a separate direct database connection from `52.40.10.231`.

Lesson 14 — Detections, Alerts & Tier 1 Triage

VOCABULARY CHECK — fill in the blank

1. A(n) **detection** is defined suspicious-behavior logic; a(n) **alert** is that logic scheduled to notify someone.
2. The 10-step triage workflow begins: Alert → **Validate** → Identify affected asset → Identify user → ...

BUILD THE SPL — fill in the missing pieces

```
index=botsv2
| stats count by src_ip
| where count > 1000
```

STUDENT EXERCISE

Pick one src_ip from the detection output above. Run a full 10-question triage and decide escalate/close.

#	Step	Finding
1	**Alert**	`45.77.65.211` exceeded the request threshold (`count > 1000`): 8,966 requests.
2	**Validate**	Real, not a false positive. 4,023 distinct paths and 8,050 errors (about 90%) match scanning: many paths, high error rate, low repeat.
3	**Affected asset**	The web server `172.31.7.2` (`store.froth.ly`, Apache on Ubuntu). **[run]** `... src_ip="45.77.65.211" | stats count by dest_ip, site` to confirm it is the only target.
4	**User**	No username in network data. The only identity evidence is session cookies (`PHPSESSID`). **[run]** Check whether any authenticated sessions or logons follow the scan.
5	**Source reputation**	External IP, likely commercial cloud hosting (as far as I know). Not internal and not a known partner. **[run]** Compare against any approved-scanner list.
6	**Behavior**	Enumeration of URLs. **[run]** Check `http_user_agent` for tools like nikto or sqlmap, and `stats count by uri_path, status` for admin/config paths.
7	**Timeline**	**[run]** `timechart span=1m count` for the burst window, then look at ±30 minutes around it.

8	**Success check**	The key unknown. **[run]** `status=200` and `http_method=POST` from this IP. About 916 requests were not errors, and any 200s on sensitive paths change the outcome.
9	**Scope**	**[run]** Does the IP appear in other sourcetypes (DNS, Windows, firewall)? Does anything else on the network behave like it?
10	**Decision**	See below.

Decision: Escalate (medium severity), provisionally

- The behavior is confirmed scanning from an external IP against a customer-facing store.
- About 916 requests did not return errors, so I can't yet rule out that it found something. Until the 200/POST check is done, closing it would be a guess.
- The earlier stack-trace leak on `store.froth.ly` means the server gives attackers useful information, which raises the stakes.

Lesson 15 — Timelines, Reporting & the Final Capstone

VOCABULARY CHECK — fill in the blank

1. The Tier 1 report field list includes: Alert, Time, Affected Host, User, Source IP, Destination IP, Observed Activity, Evidence, Assessment, Severity, Recommended Action, and **Escalation** .
2. Rule: write "the evidence indicates..." rather than "**the attacker did...**"

BUILD THE SPL — fill in the missing pieces

```
index=botsv2 host="mercury" earliest="08/29/2017:18:06:00" latest="08/29/2017:19:06:00"
| table _time sourcetype user src_ip dest_ip action process command
| sort _time
```

STUDENT EXERCISE

Complete the reporting template for any prior lab using only evidence-based language.

Field	Entry
Alert	Source IP exceeded the request-volume threshold (`count > 1000`) in `stream:http`.
Time	**[fill in]** First and last seen for `45.77.65.211` (from the `min(_time)` / `max(_time)` search).
Affected Host	**[fill in]** Expected to be the web server for `store.froth.ly` (`172.31.7.2`). Confirm with

	`stats count by dest_ip, site` for this source IP.
User	No username appears in the network data. No user is identified.
Source IP	45.77.65.211 (external).
Destination IP	**[fill in]** `172.31.7.2` if confirmed by the check above.
Observed Activity	The source IP made 8,966 HTTP requests covering 4,023 distinct paths. 8,050 of the requests returned errors.
Evidence	`stream:http` search: `count`=8,966, `distinct_paths`=4,023, `errors`=8,050 (about 90% of requests). **[fill in]** user agent, any 200/POST results, and the time window.
Assessment	The evidence indicates enumeration or scanning behavior: many distinct paths, a high error rate, and a low repeat rate. The evidence does not show whether any request succeeded, because the 200/POST check has not been completed. The evidence does not establish intent or the identity of the operator.
Severity	Medium (provisional). The behavior is confirmed, but impact is unconfirmed.
Recommended Action	Run the 200/POST check for this IP. Review the user agent and requested paths. Check other sourcetypes for the same IP. Consider blocking or monitoring the IP.
Escalation	Escalate to a senior analyst, because success of the requests cannot yet be ruled out. Close only if the 200/POST check shows no sensitive paths found and no related activity afterward.

Lab Worksheets 1–10

Complete each lab using your own BOTS v2 environment. Fill in every blank in the guided steps before running the search, then answer the investigation questions in the space provided.

Lab 1 — Find Your Data

Scenario: You are a newly hired Tier 1 Analyst. Your first task is to understand what telemetry is available in the SIEM before investigating anything.

GUIDED STEPS — fill in the blanks

```
index=botsv2 earliest=0
| stats count

index=botsv2 earliest=0
| stats count by sourcetype
| sort - count

index=botsv2 earliest=0
| stats count by host
```

INVESTIGATION QUESTIONS

1. How much data exists in total? `68870348` events in the `botsv2` index
2. How many distinct sourcetypes are present? `103` distinct sourcetypes.
3. Which sourcetype contains the most events? `mysql:server:stats` with `13579885` events
4. What categories of security telemetry appear to be available (Windows, network, web, DNS, etc.)?
   - **Web/network:** `stream:http` (HTTP traffic to `store.froth.ly`)
   - **Windows:** `WinEventLog:Security` (logons, privileges, logoffs on `mercury`)
   - **DNS:** `stream:dns`

Analyst conclusion (benign / suspicious / malicious, with evidence):

The evidence indicates scanning behavior from the external IP `45.77.65.211`: 8,966 requests, 4,023 distinct paths, and 8,050 errors (about 90%) against the web server for `store.froth.ly`. The evidence does not show whether any request succeeded, and it does not establish intent, so I rate this suspicious, not malicious. The high activity on `service3` (206,520 events, a repeating logon, privilege, and logoff cycle on `mercury`) matches automated service behavior, and the evidence does not indicate it is suspicious.

Escalation decision:

Escalate to a senior analyst, because the evidence cannot yet rule out that any request from `45.77.65.211` succeeded, and the target is customer-facing. I would downgrade to close if a check of `status=200` and POST requests from this IP shows no sensitive paths found and no related activity afterward.

Lab 2 — Investigate a Suspicious IP

Scenario: Threat intelligence reports a suspicious IP address. Your task is to determine whether systems in the environment communicated with it.

GUIDED STEPS — fill in the blanks

```
index=botsv2
| stats count by src_ip
| sort - count   (use this to pick a candidate IP)

index=botsv2 src_ip="45.77.65.211"

index=botsv2 src_ip="45.77.65.211"
| stats count by src_ip sourcetype
```

INVESTIGATION QUESTIONS

1. Is this an isolated event or repeated behavior?

Repeated. `45.77.65.211` made 8,966 HTTP requests covering 4,023 distinct paths, and 8,050 of them returned errors (about 90%). Its activity also appears in `stream:tcp` (4,855 events) and `stream:ip` (4,854 events).

2. Which host and user are tied to this activity?

- **Target:** `172.31.4.249` (`www.brewertalk.com`)
- **Capture host:** `gacrux`
- **User:** none identified. Network data has no username field.

3. What time window does the activity span?

08/11/2017 22:40:57 to 08/16/2017 23:25:19 (about 5 days). The timeline window with ±30 minutes is 22:10:57 on 08/11 to 23:55:19 on 08/16. The activity is bursty, with most events in the 22:00 hour on 08/11.

4. What port and protocol are involved?

Port 80, HTTP over TCP (`stream:http`, with supporting `stream:tcp` and `stream:ip`).

- A second external IP, `52.40.10.231`, communicated with the same server from 08/11 22:30:05 to 08/16 23:31:59. It produced 3,164 `stream:mysql` events on port 3306, plus 12 HTTP events on port 80.
- A second burst at 08/12 17:00 was mostly database, `auditd`, `linux_audit`, and `linux_secure` events, with very little web traffic.
- Other external IPs also touched the server, including `116.31.116.17` and `71.39.18.125`.

Analyst conclusion (benign / suspicious / malicious, with evidence):

The evidence indicates repeated scanning-like behavior from the external IP `45.77.65.211` against `www.brewertalk.com` (`172.31.4.249`): 8,966 requests, 4,023 distinct paths, and about 90% errors, over port 80 between 08/11/2017 22:40:57 and 08/16/2017 23:25:19. The timeline also shows a separate external IP, `52.40.10.231`, connecting directly to MySQL port 3306 on the same server (3,164 events), and a second burst of database and Linux auth/audit activity at 08/12 17:00. The evidence does not show whether any scanner request succeeded, who operates either IP, whether the two IPs are related, or whether the host was accessed. I rate this suspicious, not malicious, because intent and impact are not established.

Escalation decision:

Escalate to a senior analyst. Reasons: (1) success of the scanner's requests is not yet ruled out, (2) an external IP reached the database port 3306 directly, and (3) the 08/12 17:00 burst shows database and Linux authentication activity that needs review. Recommended actions: check 200 and POST responses from `45.77.65.211`, review `linux_secure` for accepted or failed logins on `gacrux`, check whether port 3306 should be reachable from the internet, and consider blocking or monitoring both external IPs.

Lab 3 — Suspicious User Activity

Scenario: The SOC received a report that a user account may have been compromised.

GUIDED STEPS — fill in the blanks

```
index=botsv2 earliest=0 sourcetype="WinEventLog:Security" Account_Name="service3"
| table _time host Account_Name Source_Network_Address EventCode
| sort _time
```

INVESTIGATION QUESTIONS

1. Where did the user authenticate from? `service3` authenticated almost entirely (68,652 of 68,662 logons) from internal address `10.0.1.1` using logon type 3 (network). Nine logons came from `10.0.2.107` (also type 3), and one was a type 5 service logon with no source address.
2. When did the activity occur? Starting 08/04/2017 02:02:33 on `mercury`. **[fill in]** the end time with `stats min(_time) max(_time)`. The last event you saw earlier was 08/29/2017 around 18:36.
3. Which systems were involved? `mercury` in all rows viewed. **[fill in]** confirm with `stats count by host`.
4. Was there suspicious activity immediately after login? Yes. The evidence shows 501 process creations and a set of account-management events (3 accounts created and enabled, 3 password reset attempts, group membership changes, 6 account modifications) and one audit-log clear, all tied to `service3` events. **[fill in]** the timing relative to logons and whether `service3` was the actor or target.
5. Does the overall pattern look normal for this account? No. The repeating 4624, 4672, 4634 cycle matches a service account, but this set of events does not. The evidence indicates the account's activity is not limited to the routine cycle.

Analyst conclusion (benign / suspicious / malicious, with evidence):

The evidence indicates `service3` on `mercury` shows a routine, repeating logon cycle (206,520 events) from internal source `10.0.1.1`. It is also associated with events that are not routine for a service account: 501 process creations, 3 account creations (4720) and enablements (4722), 3 password reset attempts (4724), group membership changes (4728, 4732, 4735), 6 account modifications (4738), and one audit-log clear (1102). Nine network logons from `10.0.2.107` also differ from the account's normal source. The evidence does not yet show whether `service3` performed these actions or was the target of them, who is behind them, or whether they are authorized administration. I therefore rate this suspicious, not malicious.

Escalation decision:

Escalate to a senior analyst as a possible account compromise with persistence indicators. Reasons: account creation and group changes, a cleared audit log, and a source address that differs from the account's normal pattern. Recommended actions: identify the actor and the target in the account-management events, review the new accounts and group changes, check the `10.0.2.107` logons and the timing of the 1102 event, review the 4688 processes, and consider disabling or resetting `service3` credentials and the newly created accounts if they are not authorized.

Lab 4 — DNS Investigation

Scenario: A workstation is generating unusual DNS activity.

GUIDED STEPS — fill in the blanks

```
index=botsv2 sourcetype="stream:dns"
| stats count by query{}
| sort - count
```

INVESTIGATION QUESTIONS

1. Which domain(s) stand out, and why?

   - **FHFAEBEECACACACACACACACACACACAAA (13,937):** the top entry, but not a real domain. It is a NetBIOS-encoded name that decodes to **WPAD**. This matches `wpad` (5,913) and `wpad.frothly.local` (1,362) in the same list.
   - **ENEFFCEDFFFCFJCACACACACACACACACA and ...CAAA (1,956 and 1,951):** the same encoding, decoding to **MERCURY**, a host you saw earlier.
   - **111-249-38-34.dynamic-ip.hinet.net (1,039):** a dynamic-IP hostname that, as far as I know, belongs to a Taiwan ISP. It is the only entry that looks like an outside residential address, so it is the most non-obvious.
   - The rest (`outlook.office365.com`, `manage.office.com`, `*.compute.internal`, `store.froth.ly`) look like routine Office, cloud, or internal lookups.

2. Which host queried it, and how often?

   - **Hinet domain:** only one host, `172.31.38.181`, made all **1,039** queries, between 08/19/2017 20:52:23 and 21:59:26 (about 67 minutes). No other host asked for it.
   - **Where that host sits:** `172.31.x.x` is the same range as the web servers you saw earlier (`172.31.7.2`, `172.31.4.249`), not the `10.0.x.x` workstation ranges. So it is probably a server-side host, not a workstation. Identify it before concluding anything.
   - **WPAD name:** ten or more internal `10.0.x.x` hosts, with counts from 263 to 1,291.

3. Is the query timing regular/periodic, or irregular? **Irregular**, and rising. Counts per minute ranged from 7 to 20, with no fixed interval, and increased from about 9 per minute at 20:52 to 20 per minute by 21:11. That is not a timer-based beacon. It tracks the amount of incoming mail traffic, which fits a server reacting to connections.

4. What corroborating evidence (network/HTTP) supports or weakens your hypothesis?

   - **Weakens the C2 hypothesis:** the DNS queries go only to `172.31.0.2` (the local resolver) on port 53, and the domain is explained by inbound SMTP from the matching IP. WPAD queries from the `10.0.x.x` hosts went only to `10.0.1.100`, with two forwarded to public resolvers (`8.8.8.8`, `4.4.4.4`) and one query from `10.0.4.1`, so no unexpected host appears as a destination.
   - **Still unconfirmed:** your table shows where queries were sent, not who replied, so I can't fully rule out a rogue WPAD responder.
   - **Worth noting:** a large number of SMTP connections from many dynamic-IP addresses in what look like the same ISP ranges (`111.243.x.x`, `118.165.x.x`, `118.166.x.x`, `36.225.x.x`, `1.160.x.x`). The evidence does not show whether this is normal inbound mail, spam, or an abuse attempt.

Analyst conclusion (benign / suspicious / malicious, with evidence):

The evidence indicates the unusual DNS activity comes from `172.31.38.181`, which receives inbound SMTP on port 25 from many external IPs. The domain `111-249-38-34.dynamic-ip.hinet.net` matches the top SMTP source, `111.249.38.34`, so the lookups are consistent with the server resolving the names of connecting mail clients. The query timing was irregular (7 to 20 per minute, rising over 20 minutes), not a fixed interval, and queries went only to the local resolver. WPAD lookups from about ten internal hosts went to the LLMNR multicast address and the internal DNS server, which matches routine Windows behavior. An unfamiliar domain does not equal malicious. The evidence does not show whether the SMTP volume is normal mail, spam, or abuse, and it does not confirm who answered the WPAD queries.

Escalation decision:

Close the DNS activity as explained by mail server reverse lookups, with no evidence of command and control. Do not escalate it as a compromise. I would add a low-severity note for a senior analyst to review the SMTP volume from dynamic residential IP ranges, because the evidence cannot yet distinguish normal inbound mail from spam or abuse. I would escalate if the SMTP data shows mail relayed to outside recipients, one sender repeated at high volume, or the server making outbound connections it does not normally make.

Lab 5 — Build a Basic Detection

Scenario: You have been asked to create a basic detection for unusually high connection activity.

GUIDED STEPS — fill in the blanks

```
index=botsv2
| stats count by src_ip
| sort - count

index=botsv2
| stats count by src_ip
| where count > 10
```

INVESTIGATION QUESTIONS

1. How many src_ips match at threshold > 10? **478 source IPs**
2. How many match at > 20? **413 source IPs**
3. How many match at > 50? **346 source IPs**
4. Which threshold would you recommend, and why? **None of the three**. Even the highest flags 346 IPs, which is far too many alerts for an analyst to triage. Raise the threshold to something near the 99th percentile of your data, or about 1,000, and pair it with an error-rate condition. Your scanner (45.77.65.211, 8,966 requests) would still be caught, and the alert count would drop from hundreds to a handful.

Analyst conclusion (benign / suspicious / malicious, with evidence):

Of 1,863 source IPs, 478 exceeded 10 events, 413 exceeded 20, and 346 exceeded 50, so about 19% to 26% of all IPs would alert at these thresholds. The evidence indicates that low thresholds flag a large share of ordinary traffic, because normal visitors to the store already make hundreds of requests. A count threshold alone does not separate normal from unusual activity. A threshold near the 99th percentile, or about 1,000 requests, combined with an error-rate condition, would still flag the scanning IP 45.77.65.211 (8,966 requests, about 90% errors) with far fewer alerts. The evidence does not establish that any IP flagged at 10, 20, or 50 is malicious.

Escalation decision:

Do not escalate IPs flagged only by thresholds of 10, 20, or 50, since volume alone is not suspicious and would create unmanageable alert noise. Recommend deploying a higher threshold (about the 99th percentile or 1,000) combined with an error rate above 50%, then reviewing the alert volume after a trial period and adjusting. Escalate individual IPs flagged by the tuned detection for triage, as was done for 45.77.65.211.

Lab 6 — Brute-Force Authentication Investigation

Scenario: Multiple failed logins have been reported against one account.

GUIDED STEPS — fill in the blanks

```
index=botsv2 sourcetype="WinEventLog:Security"
| stats count by user, action
| where action="failure" AND count > 5
```

INVESTIGATION QUESTIONS

1. Do the failures come from a single source or many? Single for this account: all 109 failures came from `10.0.1.220`. Across the environment there are several sources (`10.0.1.100`, `172.16.0.1`, and many external IPs on Linux).
2. Is a failure streak followed by a success? Partly. Failures from `10.0.1.220` were followed 8 minutes later by successes, but from `10.0.1.222`, not the same source. The evidence does not show a same-source success.
3. What MITRE ATT&CK technique would you consider mapping this to, and why only after reviewing evidence?

- **T1110 Brute Force** is the candidate. For `Administrator`, it is only a candidate, since the cadence looks automated and may be a misconfigured service. The `172.16.0.1` pattern fits **T1110.003 Password Spraying** better, but the volume is low.
- **T1078 Valid Accounts** applies only if the `10.0.1.222` logons are unauthorized, which isn't shown.
- Map it only after reviewing evidence, because failures alone can't separate an attacker from a stale credential.
- The separate web activity from `45.77.65.211` maps to **T1595 Active Scanning** and **T1190 Exploit Public-Facing Application**.

Analyst conclusion (benign / suspicious / malicious, with evidence):

The evidence indicates `Administrator` on `mercury` had 109 failed logons from a single internal host, `10.0.1.220`, in a repeating machine-paced cadence, and later successful logons from a different internal host, `10.0.1.222`. On `venus`, four accounts had 14 failures from `172.16.0.1`. The `MERCURY$` failures (3,162) come from `10.0.1.100` and look like a configuration issue. On Linux, many external IPs generated about 90,000 failures with no successful login from the same sources, and the three accepted logins came from other IPs that also browsed the forum admin pages like an administrator would. The evidence does not show who operates `10.0.1.220`, `10.0.1.222`, or `172.16.0.1`, whether the logons are authorized, or that any account is compromised. Separately, `45.77.65.211` sent SQL injection to `/member.php` after a 5-day scan (all 503 responses), and whether any data leaked is not established.

Escalation decision:

Escalate to a senior analyst. Identify `10.0.1.220`, `10.0.1.222`, and `172.16.0.1`, and confirm with the owner whether the `Administrator` logons from `.222` and the `root` key login are authorized. Check the SQL injection response bodies. Close the `MERCURY$` failures as a likely configuration issue if the host owner confirms.

Lab 7 — Suspicious PowerShell Activity

Scenario: An analyst suspects PowerShell misuse on a host.

GUIDED STEPS — fill in the blanks

```
index=botsv2 sourcetype="XmlWinEventLog:Microsoft-Windows-Sysmon/Operational"
| search CommandLine="*powershell*"
```

INVESTIGATION QUESTIONS

1. Is there evidence of an encoded command or download cradle? None in these events. The only command lines are `splunk-powershell.exe` and `splunk-powershell.exe --ps2`, with no `-enc`, `DownloadString`, `Net.WebClient`, or URL.
2. What is the parent process of the PowerShell execution? `splunkd.exe`, the Splunk Universal Forwarder service.
3. Is this use consistent with normal admin activity, or does it look abnormal? Why? The evidence indicates normal. It is the forwarder's own scripted-input helper, run as SYSTEM by its own service, on every monitored workstation, at the same moment, with an identical hash. A single process launched by a legitimate parent on a schedule across many hosts is what monitoring software looks like, and not what an attacker working from one foothold looks like.

Analyst conclusion (benign / suspicious / malicious, with evidence):

The evidence indicates the PowerShell activity in these Sysmon events is `splunk-powershell.exe`, the Splunk Universal Forwarder's helper, launched by `splunkd.exe` as `NT AUTHORITY\SYSTEM` on seven workstations at the same time, with an identical file hash. Its command lines (none, or `--ps2`) contain no encoded commands or download cradles. This is consistent with normal monitoring activity. The evidence does not cover the 659 executions of `powershell.exe` recorded in the Security log, so it does not show whether those were routine or misuse.

Escalation decision:

Close the Splunk helper activity as benign. Run the search that excludes it before closing the whole case. Escalate if any other `powershell.exe` execution shows an encoded or download command, an unusual parent (an office application, `wmiprvse.exe`, `wsmprovhost.exe`, or `mshta.exe`), or a user other than SYSTEM or a known administrator.

Lab 8 — Network Reconnaissance

Scenario: Possible port or host scanning is suspected.

GUIDED STEPS — fill in the blanks

```
index=botsv2
| stats dc(dest_port) by src_ip
| sort - dc(dest_port)

index=botsv2
| stats dc(dest_ip) by src_ip
| sort - dc(dest_ip)
```

INVESTIGATION QUESTIONS

1. Which src_ip touches the widest breadth of ports or destinations?`10.0.2.107`, with 566 unique destination IP addresses, the highest count in the results.
2. Does this pattern look like scanning rather than normal usage? Why? Yes. The activity looks suspicious because `10.0.1.120` contacted 5,769 unique destination ports, while `10.0.2.107` contacted 566 unique destination IP addresses. These patterns may indicate port scanning and host discovery rather than normal network usage.

Analyst conclusion (benign / suspicious / malicious, with evidence):

Suspicious. The source IP `10.0.1.120` accessed 5,769 unique destination ports, and `10.0.2.107` contacted 566 unique destination IP addresses. These findings suggest possible port scanning and host discovery. Further investigation is needed to confirm whether the activity is malicious.

Escalation decision:

Escalate to the security team for further investigation. Check the activity timestamps, connection logs, and internal devices associated with both IP addresses to determine whether the behavior is authorized or malicious.

Lab 9 — Web Attack Investigation

Scenario: Possible web exploitation attempt against an internet-facing system.

GUIDED STEPS — fill in the blanks

```
index=botsv2 sourcetype="stream:http"
| stats count by http_method uri
| sort - count
```

INVESTIGATION QUESTIONS

1. Are there unusual HTTP methods or status-code patterns? The results show frequent POST requests (570) to `/magento2/rest/default/V1/carts/mine/estimate-shipping-methods` and repeated GET requests to Magento 2 JavaScript and template files, with counts around 281–284.
2. Do any requested URIs look like exploitation attempts (e.g., admin panels, config files)? The listed URIs mainly point to Magento 2 frontend resources and a cart shipping-estimation API. No clearly malicious URI is evident in the displayed results. However, further investigation is needed to determine whether the requests are legitimate or part of an exploitation attempt.

Analyst conclusion (benign / suspicious / malicious, with evidence):

Suspicious, pending further investigation. The high request counts warrant review, but the requested paths appear consistent with normal Magento 2 functionality. The current results alone do not confirm malicious activity.

Escalation decision:

Investigate further before escalating as a confirmed incident. Review source IP addresses, HTTP status codes, and any requests for sensitive files or known exploit paths. Escalate if additional evidence indicates attempted or successful exploitation.

Lab 10 — Multi-Stage Timeline & Full Triage

Scenario: Combine findings from Labs 2, 4, and 8 into a single cross-sourcetype timeline and run a full Tier 1 triage.

GUIDED STEPS — fill in the blanks

```
index=botsv2 host="*" earliest="0" latest="now"
| table _time sourcetype user src_ip dest_ip action
| sort 0 _time
```

INVESTIGATION QUESTIONS

1. What story does the chronological sequence tell? On August 3, 2017, multiple HTTP events occurred within milliseconds. The source IP 74.130.56.117 repeatedly communicated with destination IP 172.31.7.2. This indicates repeated HTTP activity, but the provided results do not show the URLs, HTTP methods, or responses needed to determine whether it was malicious.
2. What is your final severity assessment? Low to Medium severity (suspicious, pending investigation). Repeated connections alone do not confirm an attack. Additional evidence is needed to assess the activity accurately.
3. Escalate or close — and why? Escalate for further investigation. Review HTTP request details, response codes, URLs, and correlated events from Labs 2, 4, and 8 before closing the case.

Analyst conclusion (benign / suspicious / malicious, with evidence):

Suspicious, pending investigation. On August 3, 2017, source IP 74.130.56.117 repeatedly communicated with destination IP 172.31.7.2 through HTTP. The available logs show repeated activity but do not establish successful exploitation or malicious intent. Further log correlation is required.

Escalation decision:

Escalate to Tier 2 for further investigation. Analyze HTTP requests and responses and correlate events across Labs 2, 4, and 8 to determine whether the activity represents legitimate traffic or a security incident.